



Cyber Defense (420-D03-AB)

Cyberdefense Fundamentals and Perimeter Security

Lecture — Classes 1 & 2 · Cybersecurity AEC (LEA.D8) · Competency EZ03 — To apply access control measures

Delivered Tuesday, September 1, 2026, 18:00 EDT · Cyber.SoHo · Version 1.0

Session note: the Saturday, Aug 29 class was cancelled — both sessions are delivered tonight · no date or weight changes

Educational Hub © 2026 | From the Industry to the Classroom — Building the IT's Future, Today and Together !

ALL Rights Reserved · governed by the Legal Notice, Disclaimer, and Acceptable Use Policy v1.0



Tonight's Roadmap

- Opening — welcome, the one rule, and the map of the course (10 min)
- Segment 1 — what cyber defense means: defensible, resilient, layered (16 min)
- Segment 2 — where the company touches the outside world (16 min)
- Segment 3 — cutting the network into zones — LAB_01 is graded on this (18 min)
- Segment 4 — trust levels, and the tools that watch the border (14 min)
- Segment 5 — a checklist, a team, and proof that it holds (12 min)
- Closing — LAB_01 handoff and Q_01 scope (4 min)
- After the break: supervised work time — LAB_01 starts and finishes tonight

90 min

speaking time — break at 19:30, then you build



Session Note — and How Tonight Runs

- Class 1 (Saturday, August 29) was cancelled — its content is delivered tonight
- No deliverable, due date, or grade weight changes
- Tonight also: Quiz Q_01 (2.5%) — short, multiple choice, from tonight only
- LAB_01 starts tonight and finishes in this room — both parts
- Weekday rhythm: 18:00 start · short recall · 19:30 break · supervised work time
- Saturday rhythm: 8:30 start · break at 10:30
- The work time is not padding — it is where the Procedure Manual gets written

2.5%

Q_01 tonight — strictly from tonight's material



The One Unbreakable Rule (1/2)

- You practise ONLY inside your own isolated laboratory, on machines you own —
- — or on a system with explicit WRITTEN permission, obtained BEFORE you start
- Unauthorized computer access or use is a criminal offence — Criminal Code:
 - s. 342.1 — unauthorized use of a computer
 - s. 342.2 — possession of a device to obtain unauthorized use
 - s. 430(1.1) — mischief in relation to computer data
- Penalties can include imprisonment; outside Canada, your local law applies
- The instructor never asks for — and never authorizes — any illegal act
- If an activity seems to touch a system you do not own: STOP and ask first

STOP

& ask — before touching anything not yours



The One Unbreakable Rule (2/2) — May and Never

You may:

- Practise in your isolated lab — VirtualBox, or your own free-tier AWS / Azure account
- Practise elsewhere only with the owner's written permission, obtained first
- Use snapshots and isolated virtual networks — a mistake stays inside the lab

You must never:

- Scan, probe, attack, intercept, monitor or access anything not yours — college, employer, business, website, neighbour included
- Create, install or release malicious software outside your isolated laboratory
- Attempt password, credential or interception attacks on any real account or communication
- Use any tool from this course to break any law or policy that applies to you

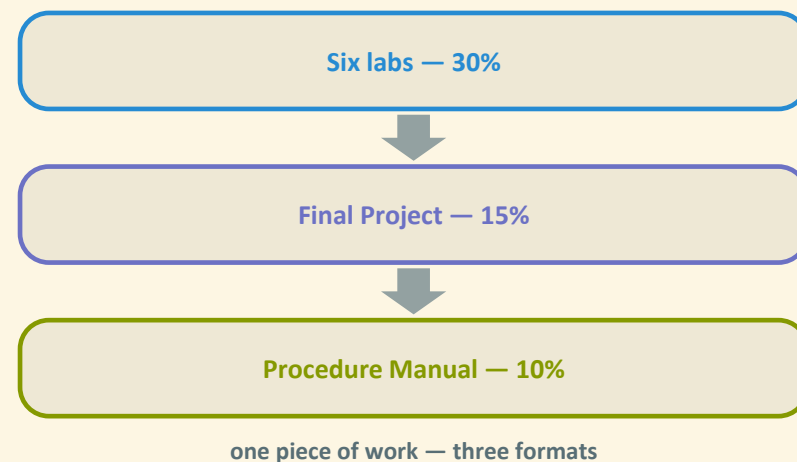
SIGN

the Acknowledgment page — every session, now



What You Will Actually Build

- Six hands-on labs — 5% each — 30% of your grade
- The Final Project (15%) — the same six labs, assembled into one defended company
- Plus one new thing only: a short resilience assessment
- The Course Procedure Manual (10%) — the same six labs, written up properly
- You are not doing three pieces of work — one piece of work, three times, in three formats
- Write each lab up the same week: the project is essentially finished by Class 17
- Leave the writing to the end: you do the whole course twice in four sessions





The Evaluation Plan — 100% of the Course

- Quizzes Q_01 to Q_04 — $4 \times 2.5\% = 10\%$ (Classes 2, 9, 14, 18)
- Hands-on labs LAB_01 to LAB_06 — $6 \times 5\% = 30\%$ (throughout)
- Mid-Term Exam — 10% (Class 10)
- Final Project — 15% (due Class 21)
- Course Procedure Manual — 10% (due Class 21)
- Final Exam — 25% (Class 23)



LAB_01 (5%) and Q_01 (2.5%) both happen tonight



Creativity — and the AI Rule

- You may use AI (Artificial Intelligence) tools in this course, at any stage
- Professionals use them daily — and so do the people attacking companies
- One absolute condition: every chapter that used AI states the LLM used —
 - — and the EXACT prompt you gave it; not a summary of the prompt — the prompt
- AI used without that disclosure = an academic-integrity matter, not a small deduction
- You may swap any suggested tool for an equivalent open-source one — say so
- Your own small helper scripts are welcome — they belong to you

EXACT

the LLM and the verbatim prompt — in every chapter



What Cyber Defense Means

- Cyber defense = making an infrastructure DEFENSIBLE and CYBER-RESILIENT
- Two different properties — you need both
- Defensible: the design makes defending it possible
 - Every machine reaching every machine, one password opening everything — not defensible
 - You cannot watch a border that does not exist
- Cyber-resilient: the business keeps running during an attack, and recovers after
 - It does NOT say 'nothing bad happens' — resilience assumes something will
 - The question: on the Tuesday morning after, can the company still work?
- This difference returns as Chapter 7 of your Final Project

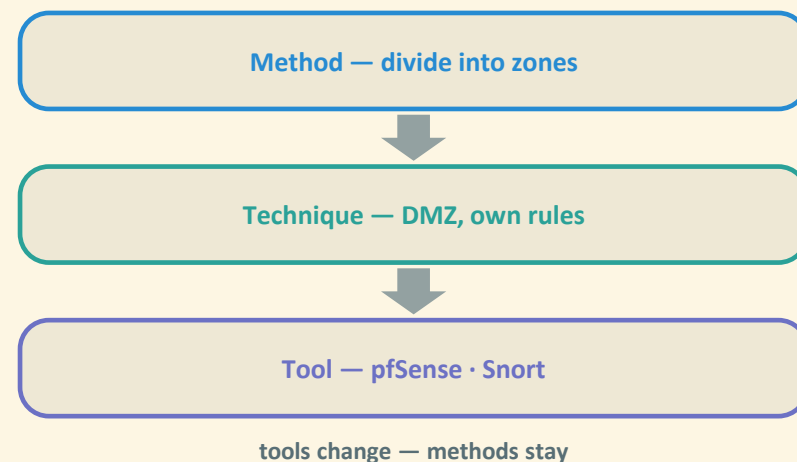
DEFENSIBLE — the design permits defence

CYBER-RESILIENT — the business keeps running



Methods, Techniques, and Tools

- A METHOD is the approach — 'divide the network into zones'
- A TECHNIQUE is how you carry it out — 'public web server in its own zone, own rules'
- A TOOL is the software that does it — pfSense, OPNsense, Defender Firewall, Snort
- Tools change every two years; methods barely change at all
- Learn the methods first — if you learn only tools, you have a shelf life





Defense in Depth — the Arithmetic

- The single most important idea of Class 1: layer several simple, imperfect protections
- One excellent control stopping 90% → 10 attempts in 100 still get through
- Five ordinary controls at 70% each → $0.3 \times 0.3 \times 0.3 \times 0.3 \times 0.3 \approx 2$ in 1,000
- Five mediocre layers beat one excellent wall — that is multiplication, not opinion
- Second reason, bigger in practice: the layers FAIL DIFFERENTLY
 - A firewall rule and a backup do not fail for the same reason on the same day
- 2026 reality: scanning for a new flaw can begin ~15 minutes after disclosure
 - If your one control is 'we patch quickly' — fifteen minutes is not quickly
- Layers buy you the hours you no longer have — and this course has six labs, not one

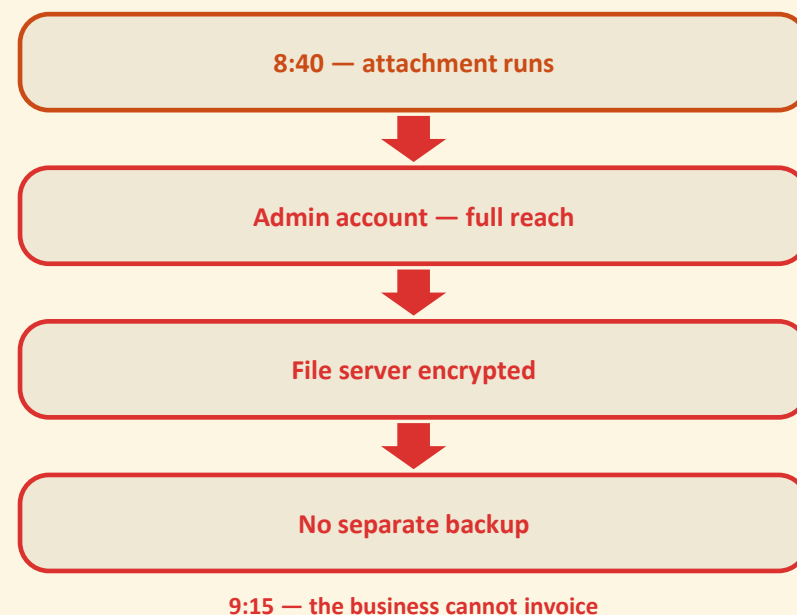
2 / 1000

attempts pass five 70% layers — vs 100 / 1000 past one 90% wall



A Tuesday at NorthMaple (1/2) — No Layers

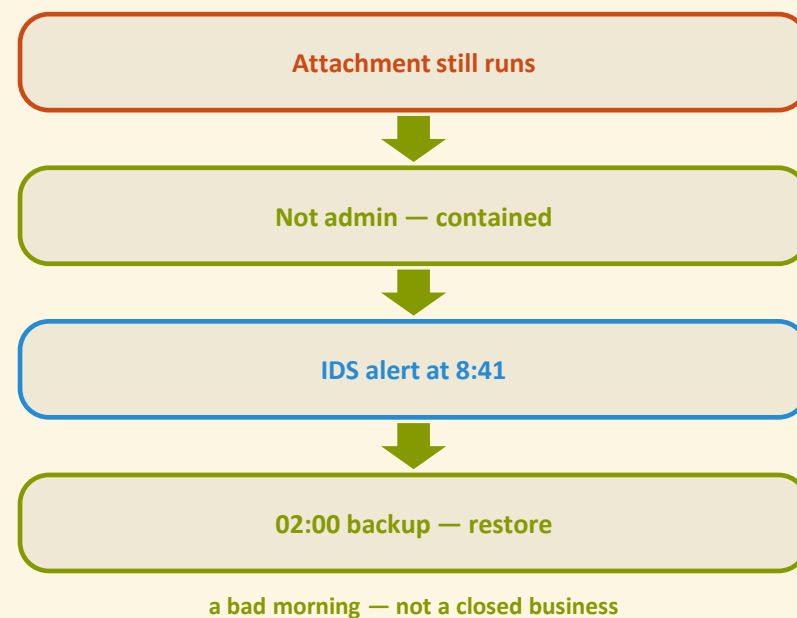
- Meet the company you defend for eleven weeks: NorthMaple Accounting Inc. (fictional)
 - Ten people · one office · public website · file server with client records · Wi-Fi · remote workers
- Tuesday, 8:40 — an accountant opens an attachment she should not have opened
- It happens in real companies every week, to careful people
- Her workstation runs it; her account is a local administrator
- Her account can reach the whole file server; there is no separate backup
- By 9:15 the client records are encrypted and the company cannot invoice
- Tax season is in four months — that company may not survive it





A Tuesday at NorthMaple (2/2) — With Layers

- Same morning, same mistake, same person — a company with the five layers you will build
- The workstation still runs the attachment — layers one and two did not catch this one
 - Notice that honestly: no layer claims to stop everything
- But her account is not an administrator — damage stops at her own files
- She reaches client records, not the technicians' or the administrator's folders
- The IDS you install in LAB_04 records unusual traffic at 8:41 and raises an alert
- The 02:00 backup sits on storage her account cannot write to
- A bad morning and a restored folder — not a closed business
- Nothing required a better firewall — it required more layers





Code Player 1 — Five Layers, Four Situations

- Five defence layers, each with an HONEST list of what it can stop
- Four situations — rows taken straight from the Chapter-7 resilience template
- The loop walks the layers from the outside inwards, as real traffic would
- Three situations stopped — each by a DIFFERENT layer: the whole argument, in three lines
- The fourth — a brand-new unknown flaw — is stopped by nothing
 - Not a bug: the honest result, and exactly why detection and recovery exist at all
- In Chapter 7, an honest 'does not withstand' + what you would add = full marks

player_02_defence_in_depth.html

```
internet scan -> 1. Perimeter filtering
stolen account -> 3. Least privilege
ransomware -> 5. Backup and recovery
unknown flaw -> NOT STOPPED by any layer
```



Three Words You Need Exactly

- ASSET — any machine, service or account the company owns and must protect
- ENTRY POINT (perimeter element) — where outside traffic is ALLOWED to reach an asset
 - The website is an entry point on purpose — strangers reaching it is the point
- ATTACK SURFACE — the complete list of entry points; not the scary ones, all of them
- ATTACK VECTOR — the route taken through an entry point; the vector is the road, the entry point is the door
- An entry point is not a mistake — those doors ARE the business
- The forgotten door: guest Wi-Fi — the signal reaches the corridor, the next office, the parking lot

DOORS

the business needs them — your job is the complete list



Production Reality 2026 — AI on the Attack Side

- For twenty years, finding a company's doors took an attacker real time — that changed
- Reconnaissance and first contact are increasingly automated with AI (RSAC 2026 framing)
- Unit 42: recon and initial access run across hundreds of targets in parallel
- KnowBe4: ~85.8% of observed phishing was AI-driven — up from ~79.9% in 2024
- Cofense (Feb 2026): AI-assisted phishing at roughly one attack every 19 seconds
- Draw exactly ONE conclusion — not 'attackers have magic now': the doors are the same doors
- The conclusion: being unknown is no longer a defence — the looking is automated, continuous, cheap
- So the defence must be structural, not lucky: the list, then the layers on the list

85.8%

of observed phishing is AI-driven — $\approx$ one attack every 19 s



The Same Tools, On Your Side

- Everything just described is available to YOU — free, open-source, offline, on your laptop
- These are model RUNNERS — they run an open-weight language model locally:
 - Ollama — runs models from one command line; the usual starting point
 - Jan — privacy-first desktop application, everything on your machine
 - Open WebUI — self-hosted web interface on top of a local runner
 - GPT4All — beginner-friendly; works on modest hardware
 - LocalAI — self-hosted, drop-in compatible interface
- You will use them defensively, starting in LAB_01 — no account, no internet connection

Ollama — one command

Jan — private desktop

Open WebUI — self-hosted UI

GPT4All — modest hardware

LocalAI — self-hosted

local · free · open-source



Four Defensive Uses — Three Hard Limits

Four uses, all inside your laboratory:

- Explain a configuration you inherited — it does not get bored on rule ninety
- Review your own design — 'what would a reviewer ask?' (you use this tonight)
- Summarize logs — a place to start looking, not a verdict
- Recognize AI-written phishing — bad spelling is no longer a warning sign

Three limits, which matter more:

- It runs LOCALLY — the company's information stays in the company
 - You VERIFY everything before it touches a configuration — you stay fully responsible
 - You DISCLOSE it — model name and exact prompt, every time, in every chapter
- One boundary, out loud: these tools DEFEND — never attack tooling, never other people's systems

LOCAL

the model runs on your machine — nothing leaves the lab



Counting NorthMaple's Doors

- NorthMaple owns seven things: website · mail relay · remote access · guest Wi-Fi radio · file server · workstations · backup target
- One yes-or-no question per system: can somebody OUTSIDE the company reach this?
 - Not 'is it important' — the file server is the most important asset and is NOT an entry point
- Website yes · mail yes · remote access yes — all on purpose
- Guest Wi-Fi yes — the one people forget
- File server no · workstations no (they start connections outwards) · backup no
- Four out of seven — that is NorthMaple's attack surface
- That number says where the strongest controls go, and where you look first

4 / 7

systems reachable from outside — the attack surface



Code Player 2 — Building the Entry-Point List

- The program writes down every system — in a real firm, from records and a walk-around, never memory
 - The commonest cause of a breach: a machine nobody remembered was connected
- Each system carries three facts: name, zone, and reachable-from-internet
- The loop visits every system — a loop cannot get bored on system six
- Yes → the entry-point list; no → printed anyway (a COMPLETE record is the point)
- len() counts the result: attack surface = 4
- Change the list to your own machines — this output is Chapter 1 evidence

player_01_perimeter_inventory.html

```
ENTRY POINT : Company website - DMZ
ENTRY POINT : Guest Wi-Fi radio - Guest
internal    : Client file server - Server
ATTACK SURFACE: 4 entry point(s) of 7
```



The Problem Zoning Solves

- A FLAT network: every machine can talk to every other machine — the default
- Plug things in, they all work, everybody is happy — and it is indefensible
- On a flat network, the security of the whole company equals its WEAKEST machine
 - Not the average — the weakest
- The visitor's phone on the Wi-Fi can reach the file server
- The web server that strangers use all day can reach the file server
- ZONING is the fix: group systems needing similar protection, control what crosses

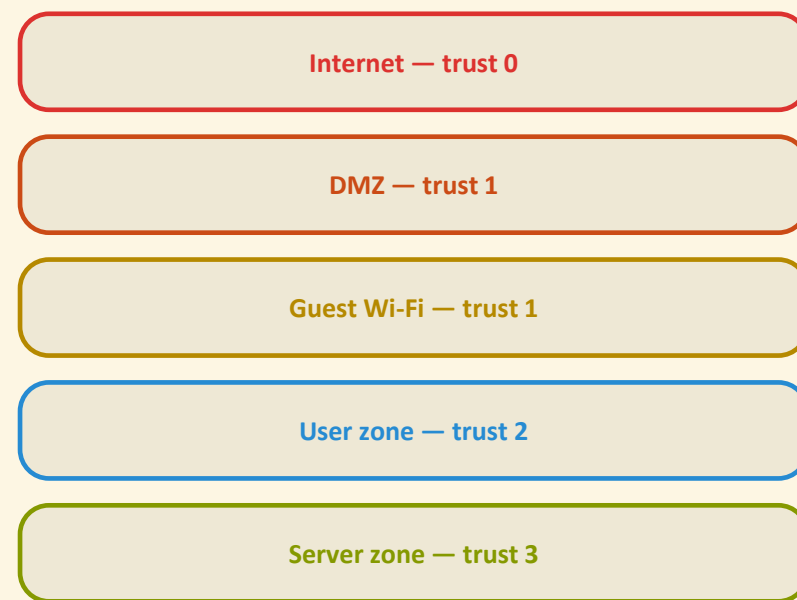
WEAKEST

a flat network equals its weakest machine



The Five Zones of This Course

- Internet — trust 0 — everybody else in the world; nothing here is under company control
- DMZ (Demilitarized Zone) — trust 1 — the public web server; strangers connect all day
- Guest Wi-Fi — trust 1 — visitor devices the company does not manage at all
- User zone — trust 2 — staff workstations and staff Wi-Fi; managed machines, real people
- Server zone — trust 3 — file server, client records, backups; the reason for the budget



five zones — controlled crossings



The DMZ, Said Properly

- A DMZ is a zone for systems that MUST be reachable from the internet —
- — arranged so a compromise of those systems does not reach anything else
- It exists for one reason: the public web server is the most exposed machine you own
- You assume it will be compromised one day, and place it where that is survivable
- Say the assumption out loud — it is the mature version of security thinking:
 - You do not put it there because you expect it to fail —
 - — you put it there because you cannot prove it will not

Internet → DMZ — HTTPS 443 ✓

DMZ → Server — denied ✗

assume the exposed machine falls — survivably



The Zoning Table — One Rule, Two Halves

- The design is not the picture — the design is the TABLE
- Half one: every system sits in EXACTLY ONE zone
 - A machine in two zones connects them — undoing the separation you just built
- Half two: every allowed flow between zones has a WRITTEN justification
 - One or two plain sentences; if you cannot write the sentence, you do not get the rule
- And the most important line nobody writes down: anything NOT in the table is DENIED
- Allow-everything-except-bad can never be finished — the bad list is infinite
- Deny-everything-except-written is finished the day the list is written

DENY

anything not in the table — the line that finishes the design



Production Reality 2026 — Cloud & Zero Trust

- The same idea in the cloud: security groups, network security groups, virtual private clouds
- Different words, same table — which sources reach which destinations, on which ports, and why
- The LAB_01 zoning table is what you will write for the rest of your career, under other names
- The industry is pushing this idea FURTHER, not away: zero trust and microsegmentation
 - Controls around individual workloads; no traffic trusted just for being inside
- We start with five zones because five you understand completely beat fifty you copied
- The direction of travel is MORE separation, not less

SAME

security groups · VPCs · zero trust — different names, one table



“Where Does the Website Go?”

- NorthMaple wants a website — simple request; where does the machine go?
- Wrong 1 — the server zone, 'they are both servers': if the website falls, the records fall the same afternoon
- Wrong 2 — the user zone, 'there is space': strangers get a permitted path to where staff work
- Right — the DMZ, with two rules:
 - Internet may reach it on HTTPS 443 — that is the business need
 - The DMZ may NOT reach the server zone — no exceptions, no 'just for the database'
- Payoff in Chapter 7, row 3: 'Withstands — the web server is isolated in the DMZ, and the firewall denies DMZ to Server'
- One line in a table tonight = one graded row in October = a survivable breach in a real firm

Server zone — ✗ records fall with it

User zone — ✗ strangers reach staff

DMZ — ✓ isolated, 443 only

Chapter 7, row 3: Withstands



Code Player 3 — The Zoning Validator

- The two LAB_01 rules, run as a program against a zoning table
- The table contains two DELIBERATE mistakes — a check that finds nothing teaches nothing
- Rule one broken: the Linux workstation has no zone
- Rule two broken: DMZ → Server has no written reason
 - The check does not know that flow is dangerous — it only knows nobody wrote a reason; that is often enough
- Collect problems first, judge at the end — never stop at the first mistake
- Run it before you submit: a table that prints PASS cannot lose those marks

player_03_zoning_validator.html

```
FAIL - 2 problem(s) found:  
- No zone given for: Linux workstation  
- No justification: DMZ -> Server  
fix · rerun · submit only on PASS
```



Trust Is a Direction

- Each zone gets a number, 0 to 3 — recording ONE thing: how much control the company has there
- Internet 0 · Guest 1 · DMZ 1 · User 2 · Server 3
- Going DOWN in trust (User → Internet): normal — write it down and move on
- Going UP in trust: this is the direction attacks travel
 - Every climb is written down, justified, narrowed to one service, and inspected
- Staying LEVEL (DMZ ↔ Guest): separated on purpose — a very strong reason, or it should not exist
- Internet → DMZ on HTTPS climbs — and is fine: justified, narrowed, inspected
- DMZ → Server climbs — and is not: no acceptable justification exists
- The direction tells you where to look; the justification tells you what to decide

UP — inspect · justify · or deny

DOWN — normal, write it down

SAME — separated on purpose



The Tools That Watch the Crossings

- Network firewall (pfSense, OPNsense) — allows or blocks between zones, per your table — LAB_05
- Host firewall (Defender Firewall, UFW, firewalld) — same idea on one machine, for when something is already inside — LAB_03
- IDS / IPS (Snort, Suricata) — detection reports suspicious traffic; prevention blocks it — LAB_04
- VPN (WireGuard, OpenVPN) — carries a remote worker across the border, encrypted — LAB_06
- Logging and monitoring — records what crossed, so next month's question has an answer — throughout
- The firewall DECIDES, the IDS NOTICES, the VPN CARRIES, the logs REMEMBER
- 'We have a firewall, we are covered' = one layer and three gaps

4 JOBS

decide · notice · carry · remember



Four Requests, One Week — and One Refusal

- 1 — The website must be public: Internet (0) → DMZ (1) — climbs, justified, it IS the business
 - Approved: narrowed to HTTPS 443 only, inspected by the firewall
- 2 — Staff need the web: User (2) → Internet (0) — descends; approved, written down
- 3 — 'The website needs the file server, just for the portal database': DMZ (1) → Server (3)
 - Climbs two levels into the most protected zone, from the most exposed machine — DENIED
 - If data is truly needed, it comes TO the portal, its own copy, only what it needs
- 4 — A visitor wants to print from guest Wi-Fi: Guest (1) → User (2) — climbs
 - Denied — or its own tightly scoped path to one printer and nothing else
- Neither asker is malicious — the table answers, not whoever asked most persuasively on a Friday

Internet → DMZ 443 — ✓

User → Internet — ✓

DMZ → Server — ✗ deny

Guest → User — ✗ deny



Code Player 4 — Which Flows Climb in Trust

- PowerShell — already on every Windows machine; reads a list, prints a table, changes nothing
- Each zone paired with its trust number; each flow read at both ends
- Destination higher than source = climbing = the risky direction
- The output is a REVIEW SHEET for the LAB_05 firewall rules
- Three flows climb; one (Internet → DMZ) is justified and inspected
- Two have no acceptable reason — they become DENY rules
- The DMZ → Server deny is the single line that keeps a compromised web server away from client records

player_04_trust_direction.html

```
Internet -> DMZ      : UP - justified
User -> Internet    : DOWN - allowed
DMZ -> Server       : UP - DENY
Guest -> User       : UP - DENY
```



The CIS Critical Security Controls

- Published free by the Center for Internet Security — the answer to 'what do I do FIRST?'
- Current version 8.1 (2024): 18 controls, 153 safeguards (one specific, measurable action each)
- Implementation Group 1 — 'essential cyber hygiene' — 56 safeguards for small organisations
- NorthMaple is exactly an IG1 company; so are most places you will work
- The first six, plainly: know your devices · know your software · know your data · configure securely · manage accounts · control access
 - The first three are all 'KNOW' — before any tool, the framework asks for lists
 - The same instruction as Segment 2, from a completely independent direction
- CIS also publishes the free CIS Benchmarks — your hardening checklists in LAB_03

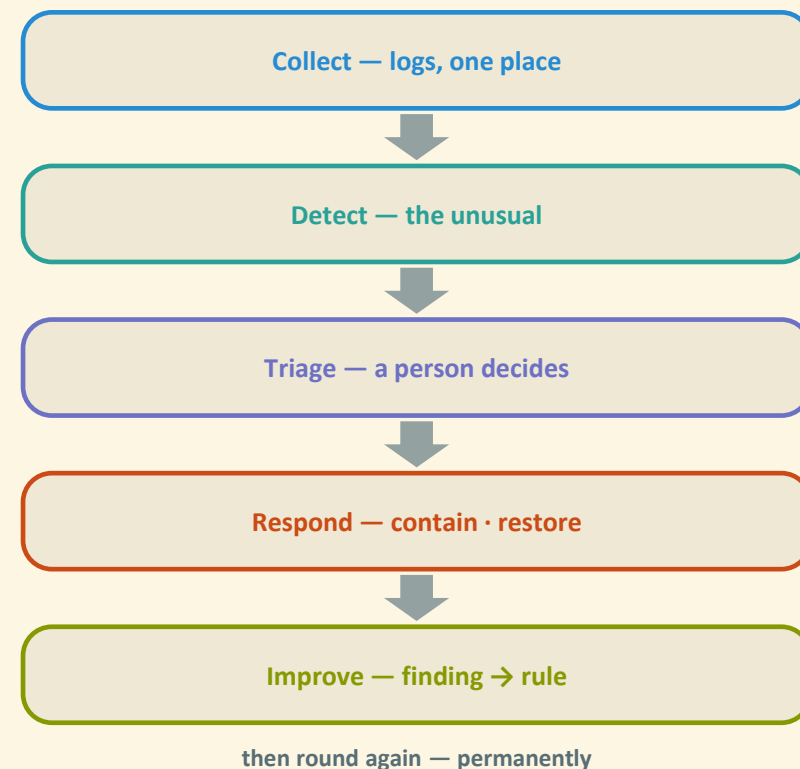
18 / 153

controls / safeguards — v8.1 · IG1 = 56 for small firms



The SOC — a Function, Not a Room

- SOC (Security Operations Center): the team that watches CONTINUOUSLY and acts on findings
- Five people in-house, or an outside service a small firm pays for
- NorthMaple will never have its own — it buys one, or an accountant notices something odd
- Why it matters tonight: step one is COLLECT — and collecting only works if the network has a shape
- On a flat network everything is 'normal', because everything already talks to everything
- Your zoning table is what makes detection possible at all — zones create expectations
- 2026: AI landed hardest on TRIAGE — models do the first pass, the judgement stays human





How Resilience Is Assessed

- Not by asking 'are we secure?' — that question has no answer
- By naming a specific scenario and answering four questions:
 - Which defence layer responds?
 - Does the business keep operating?
 - How long until normal service returns?
 - What evidence proves the answer?
- That is Chapter 7 exactly: ten scenarios · layers · verdict · one plain sentence
- You already answered row 3 tonight, in the DMZ example
- 'Does not withstand' is a valid, FULL-MARKS answer when true + what you would add

HONEST

“does not withstand” + what you would add = full marks



NorthMaple's First Hygiene Score

- Week one; the owner asks the reasonable question: 'are we secure?' — replace it with six that have answers
- Written list of every device? YES — you made one tonight
- Every piece of software? NO
- Know which folder holds the client records? YES
- All default passwords changed? NO — nobody has checked the wireless access point
- One named account per person? YES · each account only what its role needs? YES
- Four out of six — and the number is the least of what you produced:
 - An honest baseline to re-measure in six weeks · a two-item work plan · a sentence that stays true

4 / 6

an honest baseline — measured again at Class 18



Code Player 5 — The Review Prompt & the Disclosure Row

- Scores the six questions; every NO becomes a work-plan line, never a 'failure'
- Builds a review request for a free LOCAL model — from your REAL gaps
- Read what it asks for: questions a reviewer would ask — not a finished design
 - The model finds your blind spots; it does not do the work you are graded on
- Prints the AI disclosure row with the prompt already inside — paste into section N.6
- The model never sees a real name, password, or address — and nothing leaves your laboratory
- That is not a course restriction — it is how firms holding financial records expect these tools used

player_05_hygiene_and_ai_review.html

Essential-hygiene score: 4 / 6

PROMPT TO GIVE THE LOCAL MODEL: ...

AI DISCLOSURE ROW (section N.6):

| 1 | <model+version> | <prompt> | ...



LAB_01 — Starts Tonight, Finishes in This Room

Part 1 — tonight:

- Set up the isolated lab: VirtualBox or your free-tier AWS / Azure · isolated network · SNAPSHOT first
- Draw NorthMaple's diagram, marking every perimeter element and entry point (Figure 1 is the model)
- Start page one of your Course Procedure Manual: the environment setup — tonight, not later

Part 2 — also tonight (sessions combined):

- Open LAB01_zoning_workbook.xlsx — every system in exactly one zone, every flow justified
- Run the validator (or the workbook's check sheet) — submit only on PASS
- Deliverable: diagram + zoning table → the architecture chapter of the Project and Chapter 1 of the Manual
- Used an AI tool? Write the disclosure row NOW, while you still remember the prompt

PASS

run the check — submit LAB_01 only on PASS



Q_01 — What Is In It

- 2.5% · short · multiple choice · strictly from Classes 1 and 2 — which is to say, tonight
- Definitions: cyber defense · defense-in-depth · cyber resilience
- Perimeter elements and entry points — and why a needed door is not a mistake
- Network zones and trust levels — why the DMZ exists, and what 'anything not in the table is denied' means
- The basic role of a SOC — the five-step loop
- Two sentences that carry most of it:
 - You cannot defend what you have not listed
 - Five imperfect layers beat one strong wall — because they fail differently

2.5%

short · multiple choice · from tonight only



Questions ?

Tonight, before you leave:

Sign today's session

Finish LAB_01 — submit on PASS

Q_01 — from tonight only

The one unbreakable rule: isolated lab only — when in doubt, STOP and ask

Next: Class 3 — Network Access Control — Wednesday, September 2

Single source of truth for tonight: the printable handout — 420-D03-AB_C01-C02_HANDOUT.docx

Educational Hub © 2026 | From the Industry to the Classroom — Building the IT's Future, Today and Together !
ALL Rights Reserved · Lecture Script — Classes 1 and 2 — Cyber Defense (420-D03-AB) — Version 1.0 — Cyber.SoHo